

Industrial Security (Bachelor)

Exercise Sheet – Section 09 Standards, Compliance, Governance

Exercise 9.1 – Map Controls

Take ten NIST SP 800-53 controls of your choice. For each, map to:

- the most relevant IEC 62443-3-3 System Requirement (SR);
- the relevant NIST CSF subcategory;
- OT feasibility: Easy / Moderate / Hard, with one-line justification.

Present as a single five-column table.

Exercise 9.2 – Choose a Security Level

Using the Section 03 water-treatment plant architecture:

1. Assign every zone a target Security Level (SL-T 1–4).
2. Justify each assignment with reference to consequence, threat actor capability, and feasibility.
3. Identify zones where SL-T 4 would be disproportionate.

Exercise 9.3 – Regulatory Gap Analysis

For a fictional mid-sized German water utility:

1. Identify which laws and standards apply (e.g. KRITIS, NIS2, B3S Wasser/Abwasser, DSGVO).
2. Pick five obligations and assess current compliance against controls discussed in this course.
3. Recommend three concrete improvements with rough cost/effort estimates.

Exercise 9.4 – Programme Sketch

Write a 1-page outline of an OT security programme for the same utility:

- Governance: who reports to whom, RACI for OT security tasks.
- Year 1 priorities (4–6 bullets).
- Three KPIs the programme will report quarterly.

Exercise 9.5 – CRA Vendor Checklist

You are reviewing a PLC supplier for compliance with the EU Cyber Resilience Act. List five concrete artefacts you would ask for (e.g. SBOM, vulnerability handling process, security-update SLA, signed firmware). For each, decide what counts as a pass and what counts as a fail.

Exercise 9.6 – Maturity Self-Assessment

Pick a maturity model from the slides (C2M2, CMMC, or IEC 62443 programme maturity). Score your institution (or a fictional plant) at each of the model's levels and propose two improvements that would raise the score by one level.